

Your Bank's Digital Side Door

@sdanndev



“Because that’s where the money is.”

Willie Sutton, Bank Robber

Why does my bank website
require my 2-factor token, but
pulling my transactions into
Quicken does not?

Personal Financial Management

PFM

Personal Financial Management (PFM)

Quicken



**PERSONAL
CAPITAL**

 **intuit**
QuickBooks

Microsoft®
Money



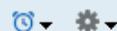
GNU**CASH**
Free Accounting Software

 **mint**.com



Accounts	
All Transactions	
Banking	\$10,698
Family Checking	2,506
My Checking	3,832
My Savings	4,800
My Credit Card	-440
Investing	\$105,986
Brokerage	26,876
401(k)	79,110
Property & Debt	\$30,261
Car Value	22,000
House	310,000
Auto Loan	-18,288
Home Loan	-283,451
Savings Goals	\$4,750
Dream Home Fund	4,050
Vacation Fund	700
Net Worth	\$151,695
+ Add an Account	

Family Checking



All Dates Any Type All Transactions Reset

Search

Date	Check #	Payee	Memo	Category	Tag	Payment	Clr	Deposit	Balance
8/5/2013		Car Payment		Auto & Transport:Auto Pay		300 00			3,556 31
8/7/2013		ATM Withdrawal		Cash & ATM		120 00			3,436 31
8/9/2013		Bo-bo- Chilli And Ribs		Food & Dining:Restaurants		75 00			3,361 31
8/10/2013		GameStop		Entertainment		12 50			3,348 81
8/10/2013		Trader Joe's		Food & Dining:Groceries		100 00			3,248 81
8/30/2013		Credit Card Payment		[My Credit Card]		750 00			2,498 81
9/1/2013		Spouse Paycheck		Net Salary Spouse				2,600 00	5,098 81
9/2/2013		Resturant		Food & Dining:Restaurants		75 00			5,023 81
9/3/2013		Grocery Store		Food & Dining:Groceries		100 00			4,923 81
9/3/2013		Gym Membership		Health & Fitness:Gym		100 00			4,823 81
9/3/2013		Netflix		Entertainment		12 50			4,811 31
9/5/2013		Gas & Electric		Bills & Utilities		250 00			4,561 31
9/5/2013		Car Payment		Auto & Transport:Auto Pay		300 00			4,261 31
9/5/2013		Mortgage Payment		Home:Mortgage		1,400 00			2,861 31
9/5/2013		Water Bill		Bills & Utilities		10 00			2,851 31
9/5/2013		Yard Work		Home:Lawn & Garden		25 00			2,826 31
9/7/2013		ATM Withdrawal		Cash & ATM		120 00			2,706 31
9/9/2013		Garder Bill		Home:Home Services		12 50			2,693 81
9/9/2013		Bo-bo- Chilli And Ribs		Food & Dining:Restaurants		75 00			2,618 81
9/10/2013		Trader Joe's		Food & Dining:Groceries		100 00			2,518 81
9/10/2013		GameStop		Entertainment		12 50			2,506 31
10/5/2013		Car Payment		Auto & Transport:Auto Pay		300 00			2,206 31
10/5/2013		Gas & Electric		Bills & Utilities		250 00			1,956 31
10/5/2013		Mortgage Payment		Home:Mortgage		1,400 00			556 31
10/9/2013		Garder Bill		Home:Home Services		12 50			543 81

647 Transactions

Current Balance: 2,506.31 Ending Balance: 543.81

Add Account

Primary Accounts

For managing your finances



Spending & Saving

Checking
Credit Card
Savings
Cash



Investing & Retirement

Brokerage
401(k) or 403(b)
IRA or Keogh Plan
529 Plan

Property & Debt

For tracking your net worth



Property & Assets

House
Vehicle
Other Asset



Loans & Debt

Loan
Home Equity Line (HELOC)
Other Liability

Business Accounting

For running your business



Invoices

Accounts Payable
Accounts Receivable

Cancel

Add Checking Account

Enter the name of your financial institution

Or choose from these popular financial institutions

AllyBank	Citibank
American Express	Discover Card Account Center
American Express Bank FSB	Fifth Third Bank - NEW
Bank of America	HSBC Bank USA
BB&T - Online Banking	PNC Bank - Web Connect
Capital One 360	Regions Financial
Capital One Bank	SunTrust Bank
Capital One Card Services	TD Bank Online Banking - New
Chase	U.S. Bank Internet Banking
Citi Cards	Wells Fargo Bank

Financial Institution not on the list? Prefer not to download? Interested in advanced connection
Use [Advanced Setup](#) to create your account.



Cancel

[Back](#)[Next](#)

Add Account

Add Checking Account

Add Checking Account

Add Checking Account

Wells Fargo Bank

Select connection method

- ☒ **Express Web Connect**
- Automatically updates balances and transactions in Quicken by connecting to your bank.
- ☐ **Direct Connect (Fees may apply)**
- Automatically updates balances and transactions in Quicken by connecting to your bank.
 - Pay your bills and transfer money directly from Quicken (services vary by bank).

[Learn more about how Quicken connects to your bank](#)

[Back](#)

[Next](#)

Q Add Account

Q Add Checking Account

Q Add Checking Account

Q Add Checking Account

Add Checking Account

Wells Fargo Bank
WEB: www.wellsfargo.com | TEL: 1-800-956-4442

Wells Fargo Bank User ID / User Name
for your online Wells Fargo Bank account

Wells Fargo Bank password
for your online Wells Fargo Bank account

 Show

☐ Save this password



Your credentials are safe with Quicken

We use bank-level encryption to secure your login credentials,
they cannot be compromised

We use a read-only connection to your bank. We cannot move
or transfer money

[Learn more about our security](#)



Cancel

For more options use [Advanced Setup](#)

Back

Connect

Add Account

Add Checking Account

Add Checking Account

Add Checking Account

Add Checking Account

Add Checking Account

Wells Fargo Bank

We found the following

BUSINESS CHECKING XX0124

Checking

Add

Nickname

Used mostly for

BUSINESS CHECKING XX0124

Personal



Cancel

Next

Add Account

Add Checking Account

Add Checking Account

Add Checking Account

Add Checking Account

Account Added

Account Added

Wells Fargo Bank

WEB: www.wellsfargo.com | TEL: 1-800-956-4442



BUSINESS CHECKING XX0124...

Downloaded and categorized transactions from the last 88 days.



Sync to Quicken Cloud
for Mobile & Alerts

The number of days of transactions that Quicken downloads is determined by your financial institution. Most financial institutions provide 90 days of your most recent transactions, but this number can vary based on financial institution policy.



Add Another Account

Finish

Quicken/Quickbooks Connection Types

Web Connect

- Unidirectional
- Manual
- Download a file
- OFX file format

Express Web Connect

- Unidirectional
- Programmatic
- Screen scrape
- Private web service

Direct Connect

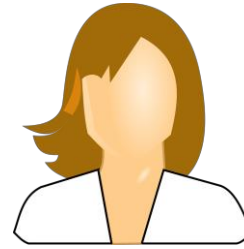
- Bidirectional
- Programmatic
- Structured query
- OFX protocol

Desktop Application

Middle-Man

Financial Institution

Web Connect



Express
Web Connect



intuit



Direct Connect



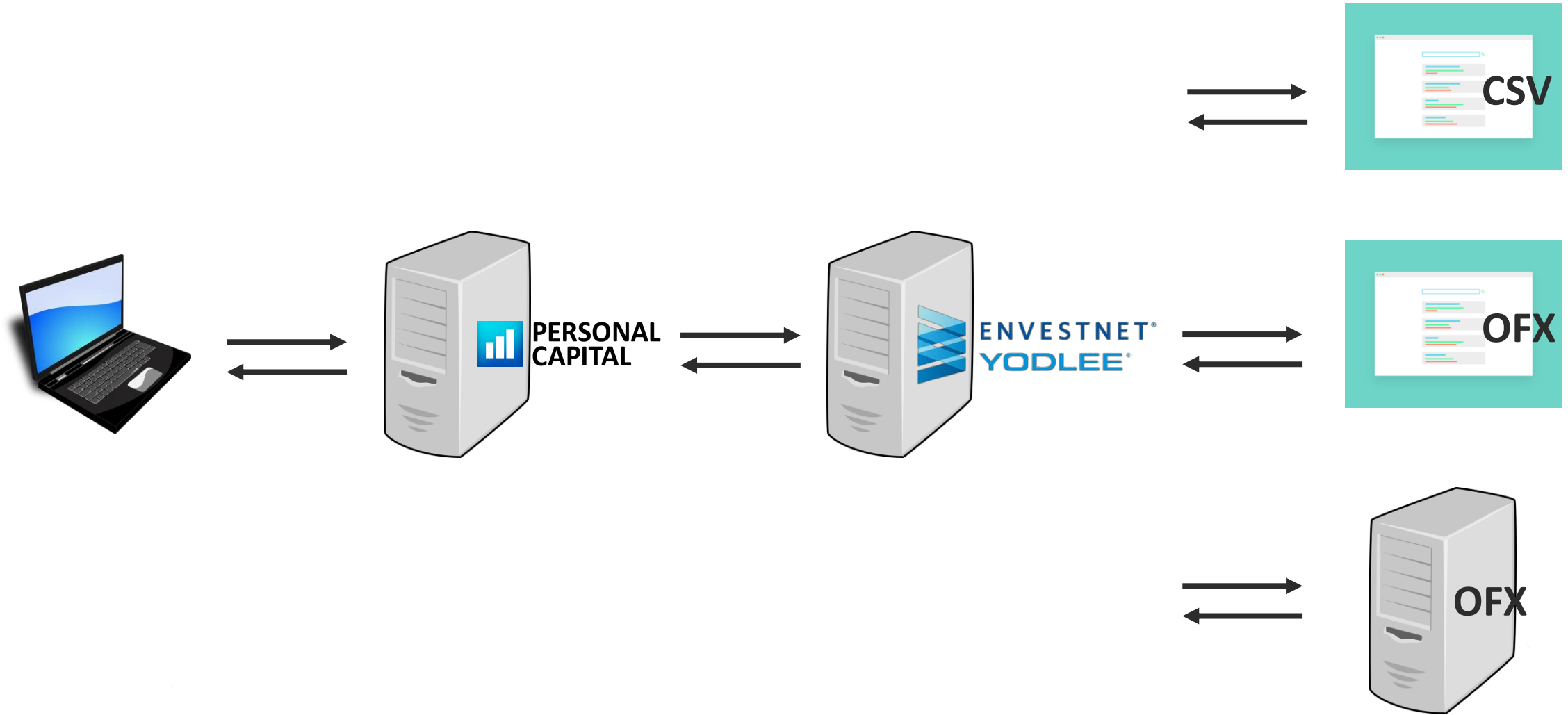
Account Aggregation Service / API



Web Application

Middle-Man

Financial Institution



Lack of Least Privilege

- Users have 1 set of bank credentials
 - Full read / write access to all accounts at financial institution
- Plain text password is shared with and stored by aggregators
- Tokenized application-based access control (OAuth) is needed

Open Financial Exchange (OFX)

aka Direct Connect

Open Financial Exchange



Specification 1.0.3

May 1, 2006

@ 2006 Intuit Inc., Microsoft Corp., CheckFree Corp. All rights reserved.

www.ofx.org

OFX Functionality - Financial

Banking

- Checking
- Savings
- CDs
- Loans

Investment

- IRA
- 401k
- Holdings
- Equity Prices

Credit Cards

- Transactions

Transfers

- Bill Pay
- Intrabank
- Interbank
- Wire Funds

OFX Functionality - Miscellaneous

- Enrollment
 - Setup online access
 - Password Reset
- FI Profile
 - Like a homepage
- Email
 - Messages and Notifications
- Synchronization
 - Ensure multiple clients receive 1-time messages
- Image download
 - JPEG, TIFF, PNG, PDF
- Bill Presentment
 - For 3rd parties

Request

```
POST /cgi/ofx HTTP/1.1
Accept: */*
Content-Type: application/x-ofx
Date: Fri, 16 Jun 2018 21:12:27 GMT
User-Agent: InetClnApp/3.0
Content-Length: 570
Connection: close
```

```
OFXHEADER:100
DATA:OFXSGML
VERSION:103
SECURITY:NONE
ENCODING:USASCII
```

```
<OFX>
  <SIGNONMSGSRQV1>
    <SONRQ>
      <DTCLIENT>20060321083010
      <USERID>12345
      <USERPASS>MyPassword
      <LANGUAGE>ENG
      <FI>
        <ORG>ABC
        <FID>000111222
      </FI>
      <APPID>MyApp
    </SONRQ>
  </SIGNONMSGSRQV1>
  ... <!--Other message sets-->
</OFX>
```

Response

```
HTTP/1.1 200 OK
Date: Fri, 16 Jun 2018 21:12:30 GMT
Content-Type: application/x-ofx
Connection: Keep-Alive
Content-Length: 2399
```

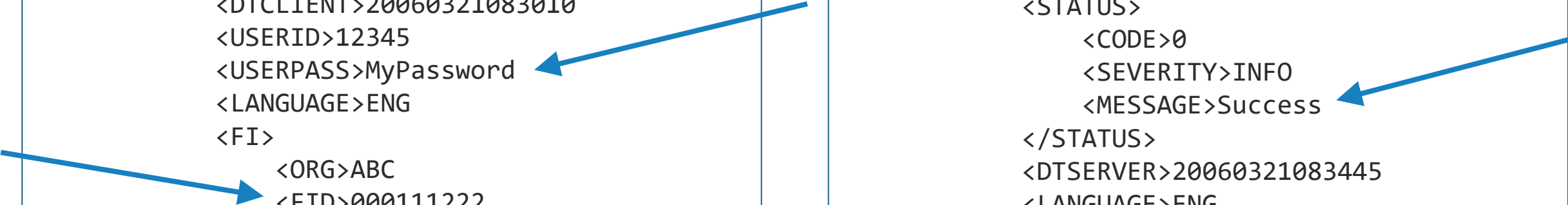
```
OFXHEADER:100
DATA:OFXSGML
VERSION:103
SECURITY:NONE
ENCODING:USASCII
```

```
<OFX>
  <SIGNONMSGRSRV1>
    <SONRS>
      <STATUS>
        <CODE>0
        <SEVERITY>INFO
        <MESSAGE>Success
      </STATUS>
      <DTSERVER>20060321083445
      <LANGUAGE>ENG
      <FI>
        <ORG>ABC
        <FID>000111222
      </FI>
    </SONRS>
  </SIGNONMSGRSRV1>
  ... <!--All other transaction responses-->
</OFX>
```

Request

```
OFXHEADER:100
DATA:OFXSGML
VERSION:103
SECURITY:NONE
ENCODING:USASCII
```

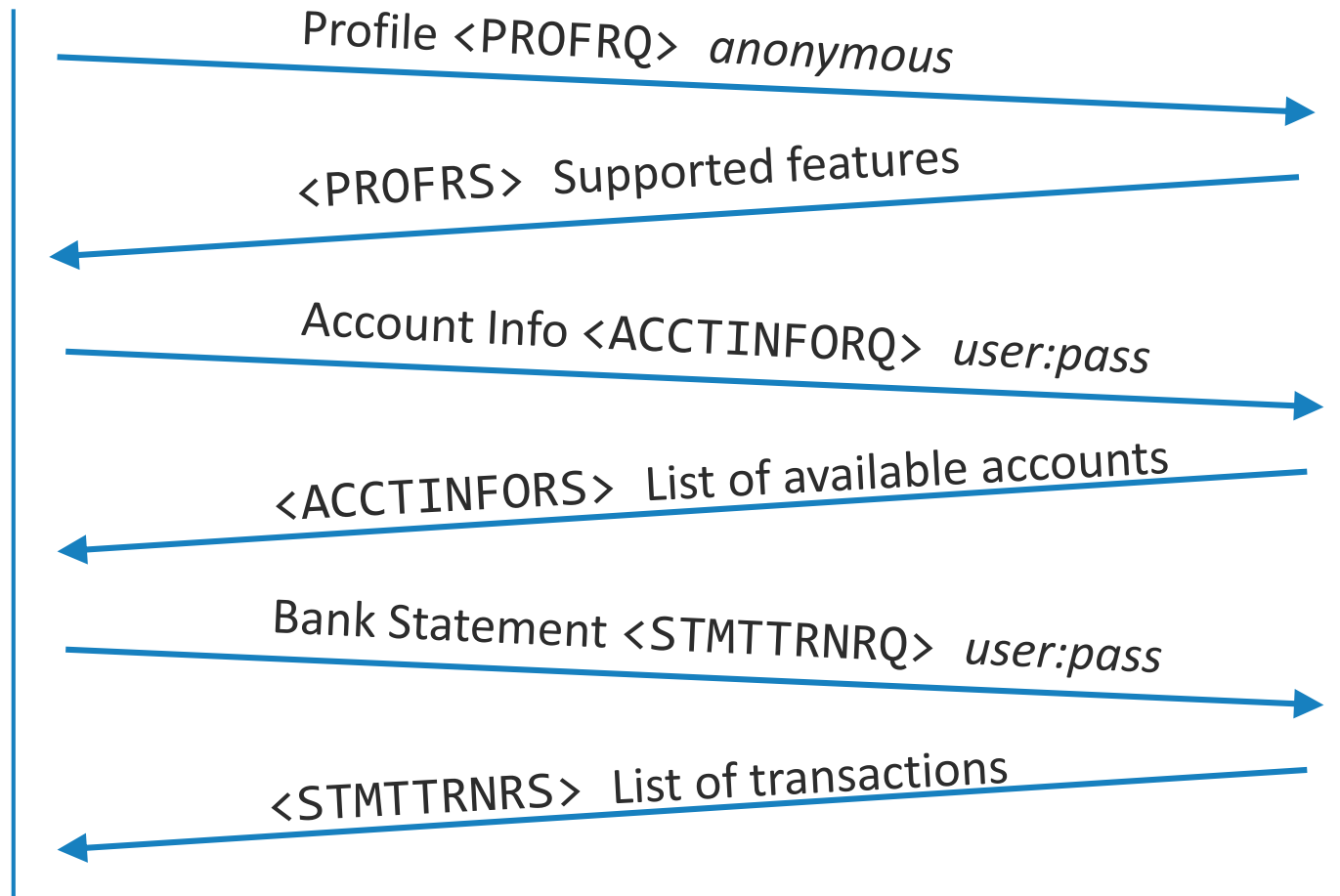
```
<OFX>
  <SIGNONMSGSRQV1>
    <SONRQ>
      <DTCLIENT>20060321083010
      <USERID>12345
      <USERPASS>MyPassword
      <LANGUAGE>ENG
      <FI>
        <ORG>ABC
        <FID>000111222
      </FI>
      <APPID>MyApp
    </SONRQ>
  </SIGNONMSGSRQV1>
  ... <!--Other message sets-->
</OFX>
```



Response

```
OFXHEADER:100
DATA:OFXSGML
VERSION:103
SECURITY:NONE
ENCODING:USASCII
```

```
<OFX>
  <SIGNONMSGSRSV1>
    <SONRS>
      <STATUS>
        <CODE>0
        <SEVERITY>INFO
        <MESSAGE>Success
      </STATUS>
      <DTSERVER>20060321083445
      <LANGUAGE>ENG
      <FI>
        <ORG>ABC
        <FID>000111222
      </FI>
    </SONRS>
  </SIGNONMSGSRSV1>
  ... <!--All other transaction responses-->
</OFX>
```



Request

```
OFXHEADER:100
DATA:OFXSGML
VERSION:103
SECURITY:NONE
ENCODING:USASCII
```

```
<OFX>
  <SIGNONMSGSRQV1>
    ... <!--Anonymous sign on-->
  </SIGNONMSGSRQV1>
  <PROFMSGSRQV1>
    <PROFTRNRQ>
      <TRNUID>5A59A330-7CEC-1000-A761
      <PROFRQ>
        <CLIENTROUTING>MSGSET
        <DTPROFUP>19900101
      </PROFRQ>
    </PROFTRNRQ>
  </PROFMSGSRQV1>
</OFX>
```



Response

```
OFXHEADER:100
DATA:OFXSGML
VERSION:103
SECURITY:NONE
ENCODING:USASCII
```

```
<OFX>
  ... <!--Anonymous sign on success-->
  <BANKMSGSET>
    <BANKMSGSETV1>
      <MSGSETCORE>
        <URL>https://o.bank.org/ofx.asp
        <LANGUAGE>ENG
        <SPNAME>Corillian Corp
      </MSGSETCORE>
      <XFERPROF>
        <PROCENDTM>235959[0:GMT]
        <CANSCHED>Y
        <CANRECUR>N
        <CANMODXFERS>N
      </XFERPROF>
    </BANKMSGSETV1>
  </BANKMSGSET>
</OFX>
```



Request

```
OFXHEADER:100
DATA:OFXSGML
VERSION:103
SECURITY:NONE
ENCODING:USASCII
```

```
<OFX>
  <SIGNONMSGSRQV1>
    ... <!--Anonymous sign on-->
  </SIGNONMSGSRQV1>
  <PROFMSGSRQV1>
    <PROFTRNRQ>
      <TRNUID>5A59A330-7CEC-1000-A761
      <PROFRQ>
        <CLIENTROUTING>MSGSET
        <DTPROFUP>19900101
      </PROFRQ>
    </PROFTRNRQ>
  </PROFMSGSRQV1>
</OFX>
```

Response

```
OFXHEADER:100
DATA:OFXSGML
VERSION:103
SECURITY:NONE
ENCODING:USASCII
```

```
<OFX>
  ... <!--Anonymous sign on success-->
  <PROFMSGRSRV1>
    <PROFTRNRS>
      <PROFRS>
        <FINAME>Bank
        <ADDR1>123 Muholland Drive
        <CITY>Las Vegas
        <STATE>NV
        <POSTALCODE>89109
        <COUNTRY>USA
        <CSPHONE>206-439-5700
        <URL>http://www.bank.org
        <EMAIL>info@bank.org
      </PROFRS>
    </PROFTRNRS>
  </PROFMSGRSRV1>
</OFX>
```



OFX Protocol Specification



Multi-Factor Authentication (MFA)

Know

- Password
- PIN
- Security Question

Have

- Token
 - Hardware
 - Software
- PKI Certificate
- Smart Card

Are

- Biometric
- Behavior

2-Step Authentication

- Password + out-of-band mechanism
 - 6 digit string
 - SMS
 - Push notification
 - Software token

OFX “MFA”

Security Question

- <USERCRED1>
 - Free form field required by server
 - Server defines label
 - Ex: “Mother’s maiden name”
- <MFACHALLENGE>
 - Security questions
 - Hard coded list
 - Ex: “Favorite color”

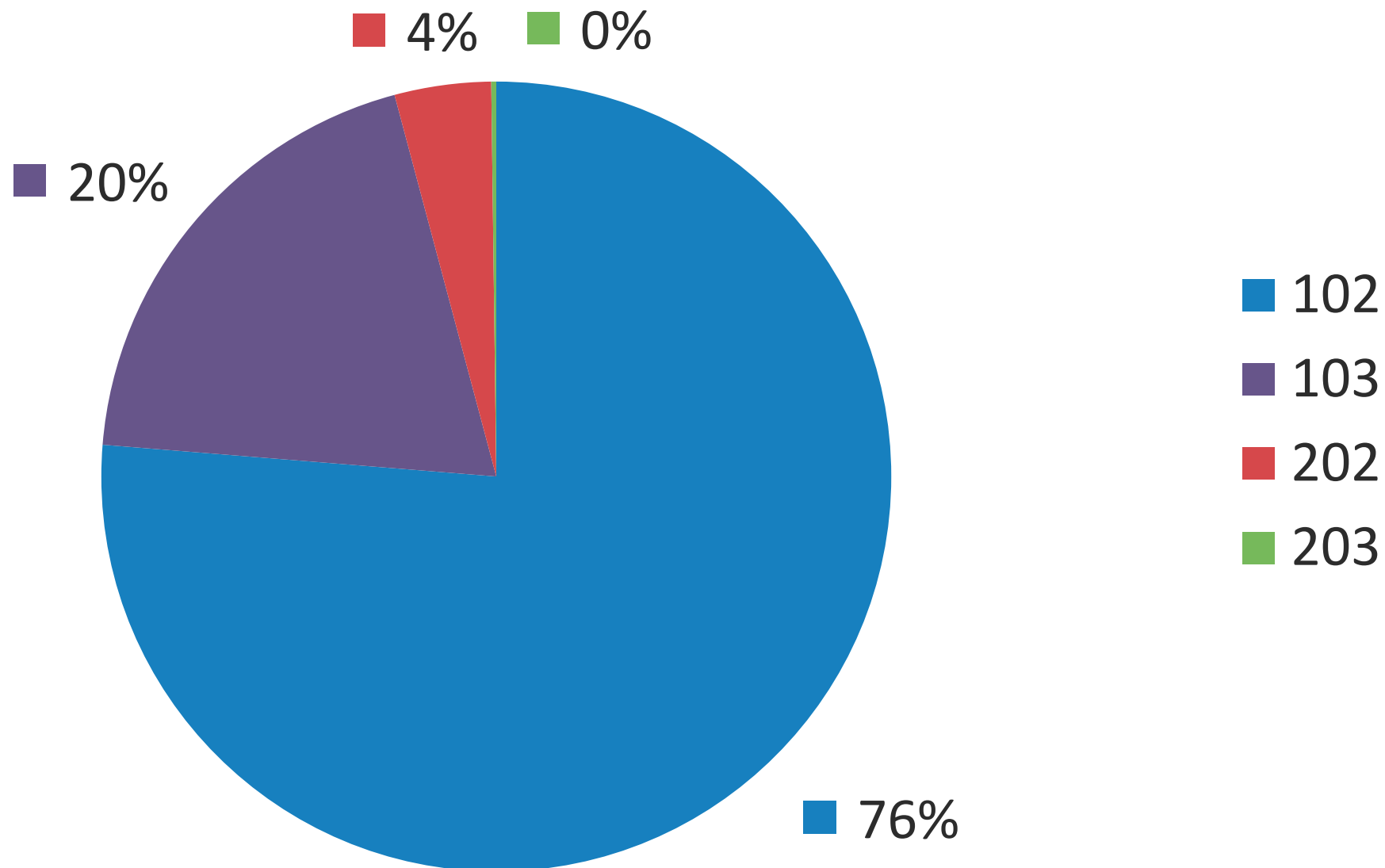
<i>Value</i>	<i>Meaning</i>
MFA1	City of birth
MFA2	Date of birth, formatted <i>MM/DD/YYYY</i>
MFA3	Debit card number
MFA4	Father's middle name
MFA5	Favorite color
MFA6	First pet's name
MFA7	Five digit ZIP code
MFA8	Grandmother's maiden name on your father's side
MFA9	Grandmother's maiden name on your mother's side
MFA10	Last four digits of your cell phone number
MFA11	Last four digits of your daytime phone number
MFA12	Last four digits of your home phone number
MFA13	Last four digits of your social security number
MFA14	Last four digits of your tax ID
MFA15	Month of birth of youngest sibling, <i>do not abbreviate</i>
MFA16	Mother's maiden name
MFA17	Mother's middle name
MFA18	Name of the company where you had your first job
MFA19	Name of the manufacturer of your first car
MFA20	Name of the street you grew up on
MFA21	Name of your high school football team; do not include high school name, e.g. " <i>Beavers</i> " rather than " <i>Central High Beavers</i> "
MFA22	Recent deposit or recent withdrawal amount
MFA23	Year of birth, formatted <i>YYYY</i>

OFX “MFA”

Static String

- <CLIENTUID>
 - Client generated ID
 - Checked by Server
 - TOFU
 - Static
- <AUTHTOKEN>
 - Server generated
 - Provided to client out-of-band
 - Implied static
 - *Could* be used for 2-step auth

Frequency of OFX Header: Version



Financial Institutions

FIs

The Big Names

Bank of America 

HSBC 

 **JPMorganChase**

CapitalOne 


citi

**Goldman
Sachs**

**WELLS
FARGO**

**AMERICAN
EXPRESS**



Yolo Federal Credit Union®

Discover the Local Difference!®



ADDITIONAL ATM LOCATED
IN LOBBY DURING
NORMAL BUSINESS HOURS



File Edit View History Tools People Help

Starting a Bank Res: x

Person 1

Secure | https://www.jackhenrybanking.com/new-banks/pages/default.aspx

HOME • ABOUT US • OUR PRODUCTS • FOR CLIENTS • CONTACT US • JACK HENRY & ASSOCIATES

jack henry Banking®

A DIVISION OF JACK HENRY & ASSOCIATES INC®

Search this site...

GO

CORE SOLUTIONS

RETAIL DELIVERY

ONLINE & MOBILE

IMAGING SOLUTIONS

JHA PAYMENT SOLUTIONS

INFORMATION SECURITY & RISK MANAGEMENT

BUSINESS INTELLIGENCE & FINANCIAL PERFORMANCE

TRAINING & CONSULTING

Click here to learn more about starting a bank.

Are you ready to start a bank?

Tips & advice for getting a bank started from Jack Henry & Associates, Inc.®

Jack Henry Banking > Starting a Bank

Starting a Bank

Starting a Bank

How We Can Help

Traditional Banks

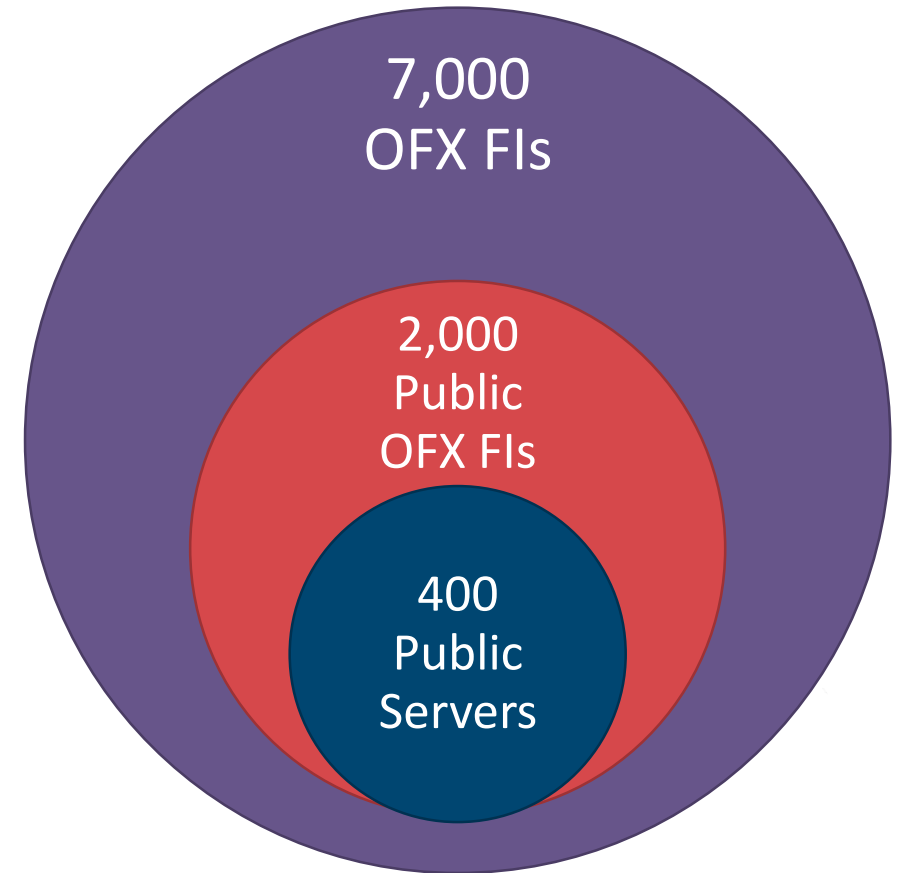
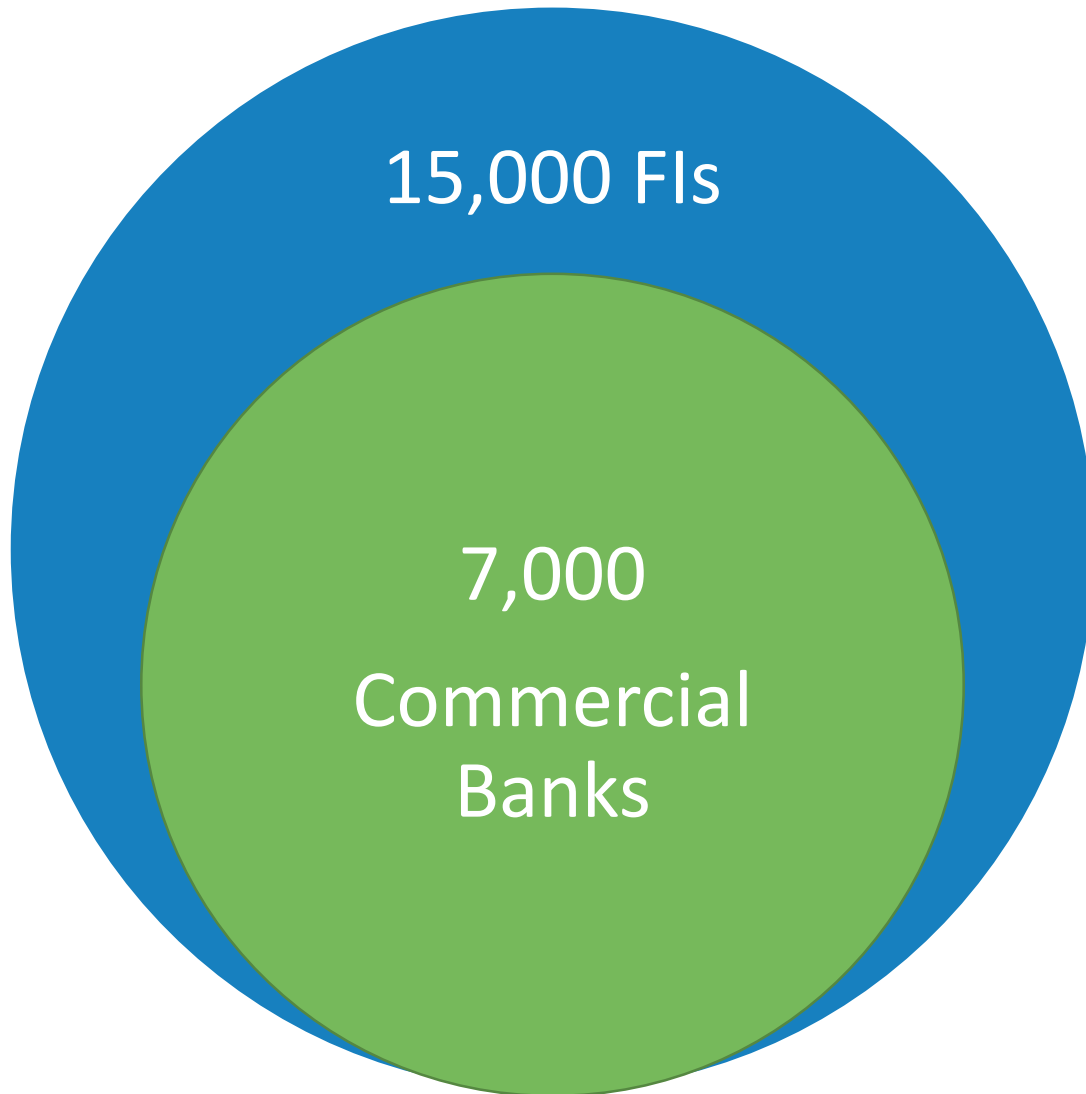
We Can Help In Starting a New Bank

Congratulations on taking the first step to exploring the possibilities of starting a new bank. You might be wondering how to start a new bank.

Case Study

First Florida Integrity Bank
Invests in Technology for De
Novo Launch

There Are A Lot of Banks!



(USA & Canada)

Investigation

OFX Survey

- What FI's are running an OFX server?
 - Find them and talk to them
- What software is providing this service?
 - Ask them simple questions

Recon

ENUM HOSTS

TLS PING

WEB SERVER

OFX SERVER

OFX PROFILE

OFX ACCOUNT

- Typical URL
 - <https://ofx.bank.com/ofx/ofxsrvr.dll>
- User Community
 - **ofxhome.org**
 - wiki.gnucash.org
- Commercial Clients
 - Branding Services
 - DNS for FIs
 - Name to OFX URL translation

Recon

ENUM HOSTS

TLS PING

WEB SERVER

OFX SERVER

OFX PROFILE

OFX ACCOUNT

- DNS
 - Stale A records?
- TLS
 - Is server certificate expired?

Stale DNS

232

Stale TLS

15

Recon

ENUM HOSTS

TLS PING

WEB SERVER

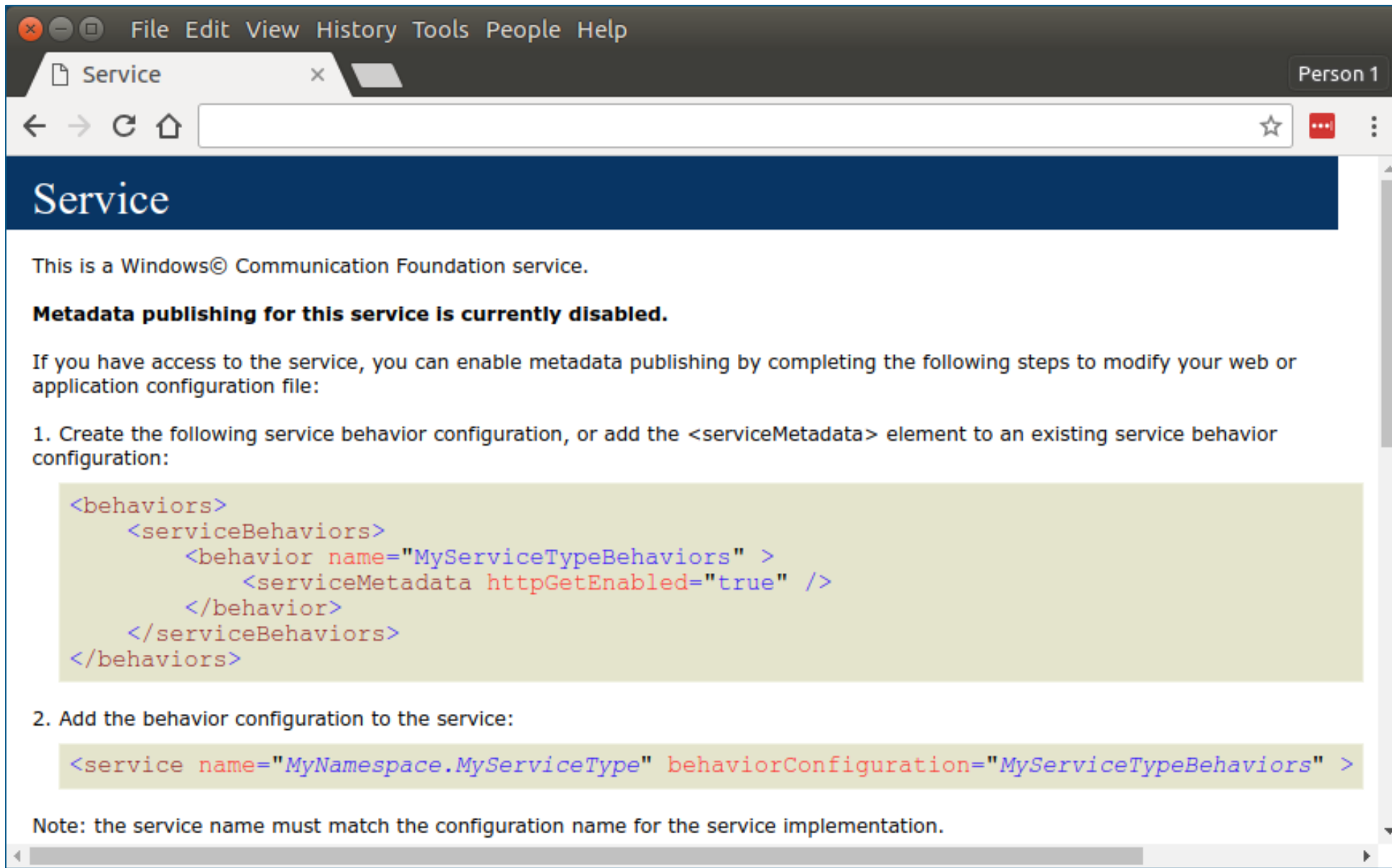
OFX SERVER

OFX PROFILE

OFX ACCOUNT

- HTTP GET /
- HTTP GET /path/ofx
- HTTP POST /path/ofx
- Fingerprint
 - Web server
 - Web application framework
 - OFX server

HTTP GET /



Service

This is a Windows® Communication Foundation service.

Metadata publishing for this service is currently disabled.

If you have access to the service, you can enable metadata publishing by completing the following steps to modify your web or application configuration file:

1. Create the following service behavior configuration, or add the `<serviceMetadata>` element to an existing service behavior configuration:

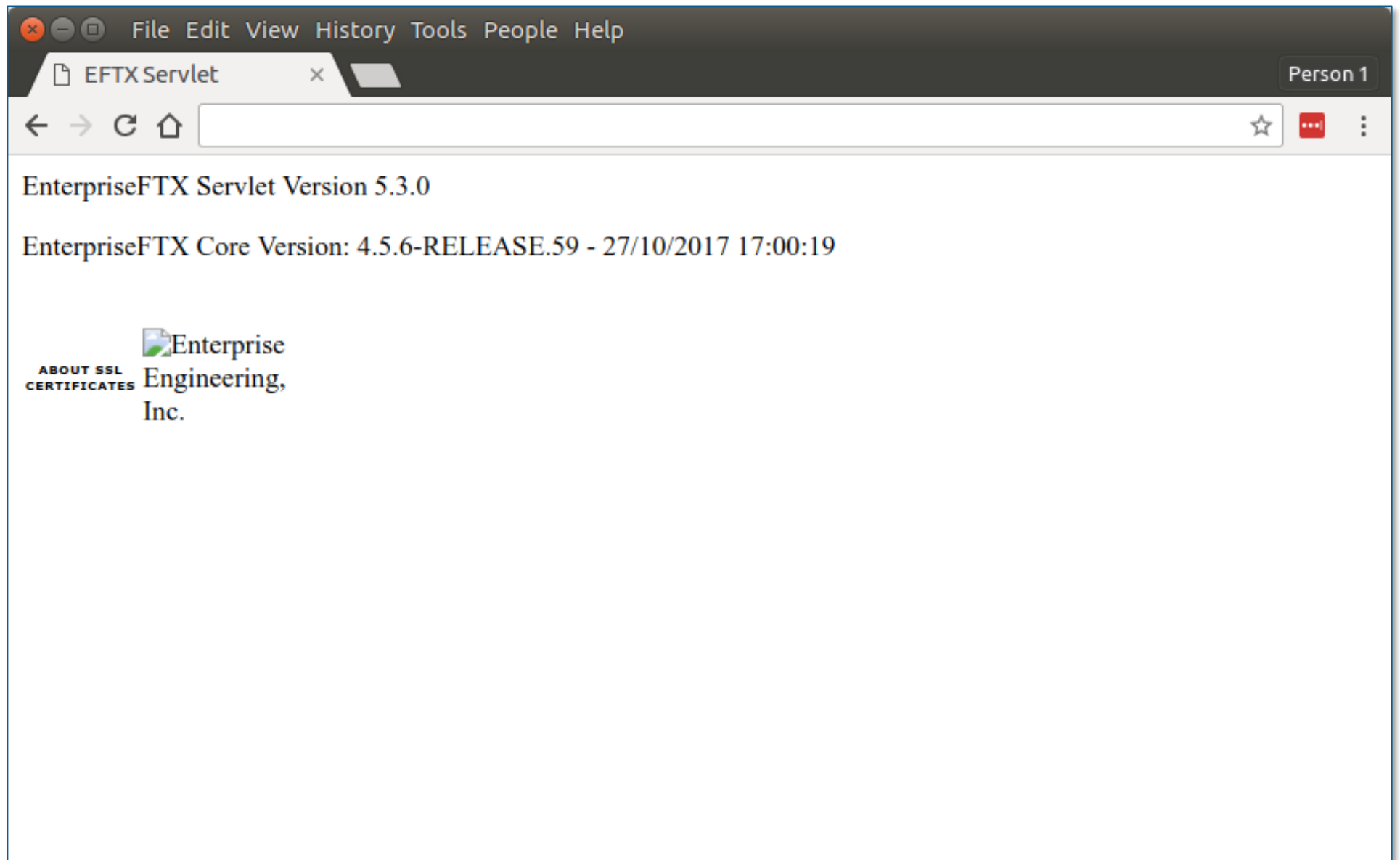
```
<behaviors>
  <serviceBehaviors>
    <behavior name="MyServiceTypeBehaviors" >
      <serviceMetadata httpGetEnabled="true" />
    </behavior>
  </serviceBehaviors>
</behaviors>
```

2. Add the behavior configuration to the service:

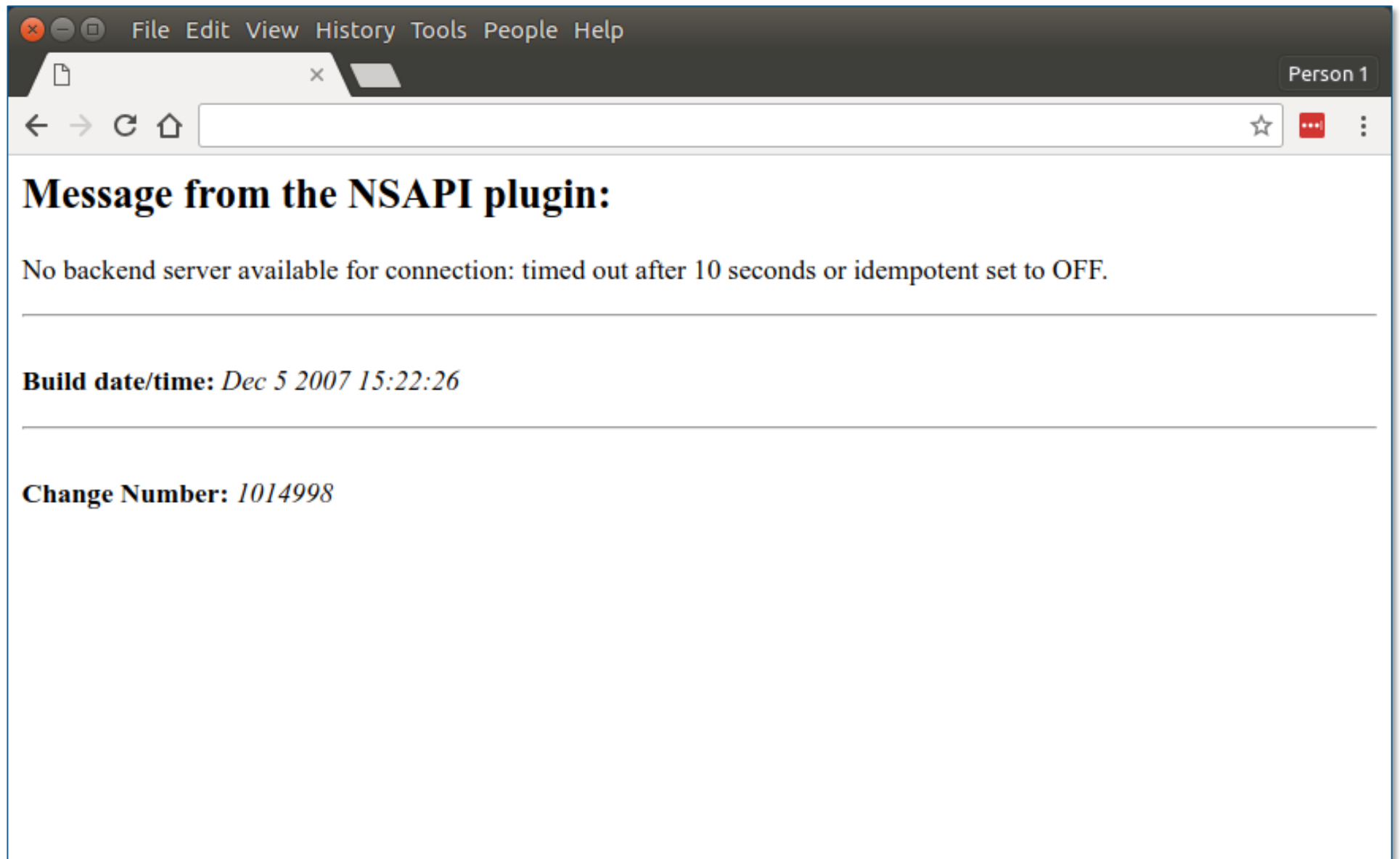
```
<service name="MyNamespace.MyServiceType" behaviorConfiguration="MyServiceTypeBehaviors" >
```

Note: the service name must match the configuration name for the service implementation.

HTTP
GET
/path/ofx



HTTP
GET
/path/ofx



Recon

ENUM HOSTS

TLS PING

WEB SERVER

OFX SERVER

OFX PROFILE

OFX ACCOUNT

- HTTP POST /path/ofx
 - <OFX></OFX>
- Fingerprint
 - Framework errors
 - OFX errors

HTTP POST /path/ofx

Request

```
OFXHEADER:100  
DATA:OFXSGML  
VERSION:102  
SECURITY:NONE  
ENCODING:USASCII
```

```
<OFX>  
</OFX>
```

Response

```
Error 500: java.lang.NullPointerException
```

HTTP POST /path/ofx

Request

```
OFXHEADER:100  
DATA:OFXSGML  
VERSION:102  
SECURITY:NONE  
ENCODING:USASCII
```

```
<OFX>  
</OFX>
```

Response

```
OFXHEADER<OFX>  
  <SIGNONMSGSRSV1>  
    <SONRS>  
      <STATUS>  
        <CODE>2000  
        <SEVERITY>ERROR  
        <MESSAGE>FID not found in file SQL State 02000  
      </STATUS>  
      <DTSERVER>20180324234025  
      <LANGUAGE>  
      <FI>  
        <ORG>  
      </FI>  
    </SONRS>  
  </SIGNONMSGSRSV1>  
</OFX>
```

HTTP POST /path/ofx

Request

OFXHEADER:100
DATA:OFXSGML
VERSION:102
SECURITY:NONE
ENCODING:USASCII

<OFX>
</OFX>

Response

Stack Trace:

<table width=100% bgcolor="#ffffcc">

<tr><td>

<code><pre>

[ArgumentOutOfRangeException: Length cannot be less than zero.

Parameter name: length]

System.String.Substring(Int32 startIndex, Int32 length) +12518387

OFX.OFX.ProcessRequest(HttpContext context) in

C:\Environment\directconnect\OFX\OFX\OFX.ashx.cs:43

System.Web.CallHandlerExecutionStep.System.Web.HttpApplication.IExecutionStep.Execute() +188

System.Web.HttpApplication.ExecuteStep(IExecutionStep step, Boolean& completedSynchronously) +69

</pre></code>

</td></tr>

</table>

Recon

ENUM HOSTS

TLS PING

WEB SERVER

OFX SERVER

OFX PROFILE

OFX ACCOUNT

- POST /path/ofx
 - <PROFRQ>
- Fingerprint
 - Spacing
 - In-house vs service provider
- Info Disclosure
 - More verbose errors
 - Long lived sessions
 - Password policy

HTTP POST /path/ofx <PROFRQ>

Request

```
OFXHEADER:100
DATA:OFXSGML
VERSION:103

<OFX>
  <SIGNONMSGSRQV1>
    <SONRQ>
      <DTCLIENT>20180319054443.123[-7:MST]
      <USERID>anonymous000000000000000000000000000000
      <USERPASS>anonymous000000000000000000000000000000
    </SONRQ>
  </SIGNONMSGSRQV1>
  <PROFMSGSRQV1>
    <PROFTRNRQ>
      <PROFRQ>
        <DTPROFUP>19900101
      </PROFRQ>
    </PROFTRNRQ>
  </PROFMSGSRQV1>
</OFX>
```

Response

```
OFXHEADER:100
DATA:OFXSGML
VERSION:103

<OFX>
  <SIGNONMSGSRSV1>
    <SONRS>
      <STATUS>
        <CODE>0
        <SEVERITY>INFO
        <MESSAGE>SUCCESS
      </STATUS>
      <DTSERVER>20180319014447.551[-4:EDT]
      <TSKEYEXPIRE>20190319120000.000[-4:EDT]
      <DTPROFUP>20081116120000.000[-5:EST]
    </SONRS>
  </SIGNONMSGSRSV1>
  <PROFMSGSRSV1>
    ...
  </PROFMSGSRSV1>
</OFX>
```

HTTP POST /path/ofx <PROFRQ>

Request

```
OFXHEADER:100
DATA:OFXSGML
VERSION:103

<OFX>
  <SIGNONMSGSRQV1>
    <SONRQ>
      <DTCLIENT>20180319054443.123[-7:MST]
      <USERID>anonymous0000000000000000000000000000
      <USERPASS>anonymous0000000000000000000000000000
    </SONRQ>
  </SIGNONMSGSRQV1>
  <PROFMSGSRQV1>
    <PROFTRNRQ>
      <PROFRQ>
        <DTPROFUP>19900101
      </PROFRQ>
    </PROFTRNRQ>
  </PROFMSGSRQV1>
</OFX>
```

Response

```
OFXHEADER:100
DATA:OFXSGML
VERSION:103

<OFX>
  ...
  <PROFMSGSRQV1>
    <PROFRQ>
      <SIGNONINFOLIST>
        <SIGNONINFO>
          <MIN>4
          <MAX>4
          <CHARTYPE>ALPHAORNUMERIC
          <CASESEN>N
          <SPECIAL>N
          <SPACES>N
        </SIGNONINFO>
      </SIGNONINFOLIST>
    </PROFRQ>
  </PROFMSGSRQV1>>
</OFX>
```

Recon

ENUM HOSTS

TLS PING

WEB SERVER

OFX SERVER

OFX PROFILE

OFX ACCOUNT

- POST /path/ofx
 - <ACCTINFORQ>
- Fingerprint
 - Error message

HTTP POST /path/ofx <ACCTINFORQ>

Request

OFXHEADER:100

DATA:OFXSGML

VERSION:103

<OFX>

<SIGNONMSGSRQV1>

<SONRQ>

<USERID>anonymous000000000000000000000000

<USERPASS>anonymous000000000000000000000000

</SONRQ>

</SIGNONMSGSRQV1>

<SIGNUPMSGSRQV1>

<ACCTINFOTRNRQ>

<ACCTINFORQ>

<DTACCTUP>19900101

</ACCTINFORQ>

</ACCTINFOTRNRQ>

</SIGNUPMSGSRQV1></OFX>

HTTP POST /path/ofx <ACCTINFORQ>

Response(s)

<MESSAGE>SUCCESS

<MESSAGE>Signon VALUES (for example, USER ID or Password) invalid.

<MESSAGE>Signon invalid

<MESSAGE>User id password combination incorrect

<MESSAGE>Could not process request

<MESSAGE>Invalid FID sent in Request

<MESSAGE>Unable to retrieve FI configuration.

<MESSAGE>UserID/PIN is incorrect.

<MESSAGE>Unsupported operation for anonymous user

<MESSAGE>No Accounts Returned

<MESSAGE><FI> Missing or Invalid in <SONRQ>

<MESSAGE>Account Not Found

<MESSAGE>There was a problem verifying the UserId/Password

<MESSAGE>Client up to date

<MESSAGE>Please contact your financial institution to enroll.

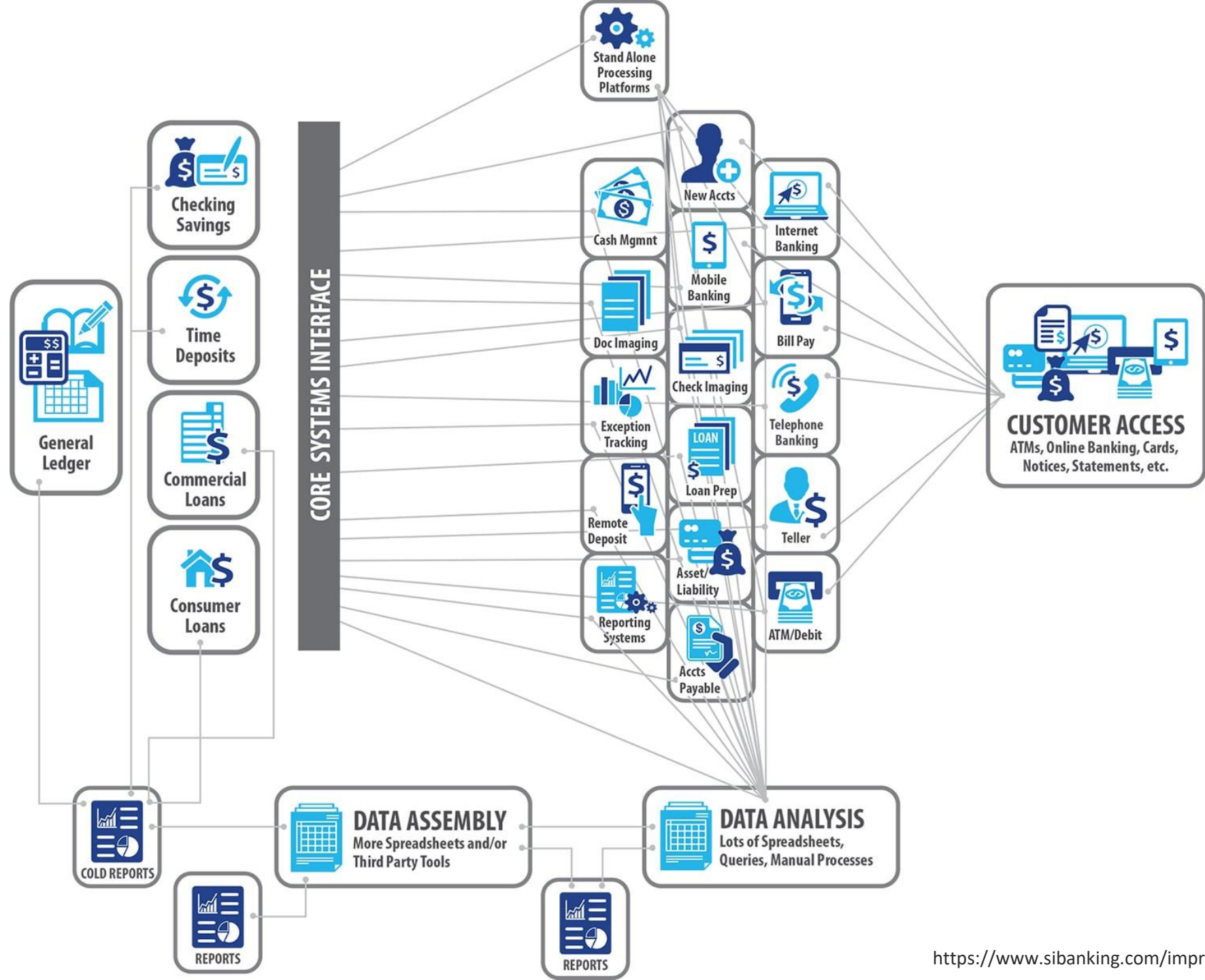
<MESSAGE>Invalid session

<MESSAGE>General error (ERROR) The server encountered an error.

<MESSAGE>General Error

<MESSAGE>Account information request could not be completed at this time. Please contact your financial institution for assistance.

Financial Software Vendors



Where Do I Buy?

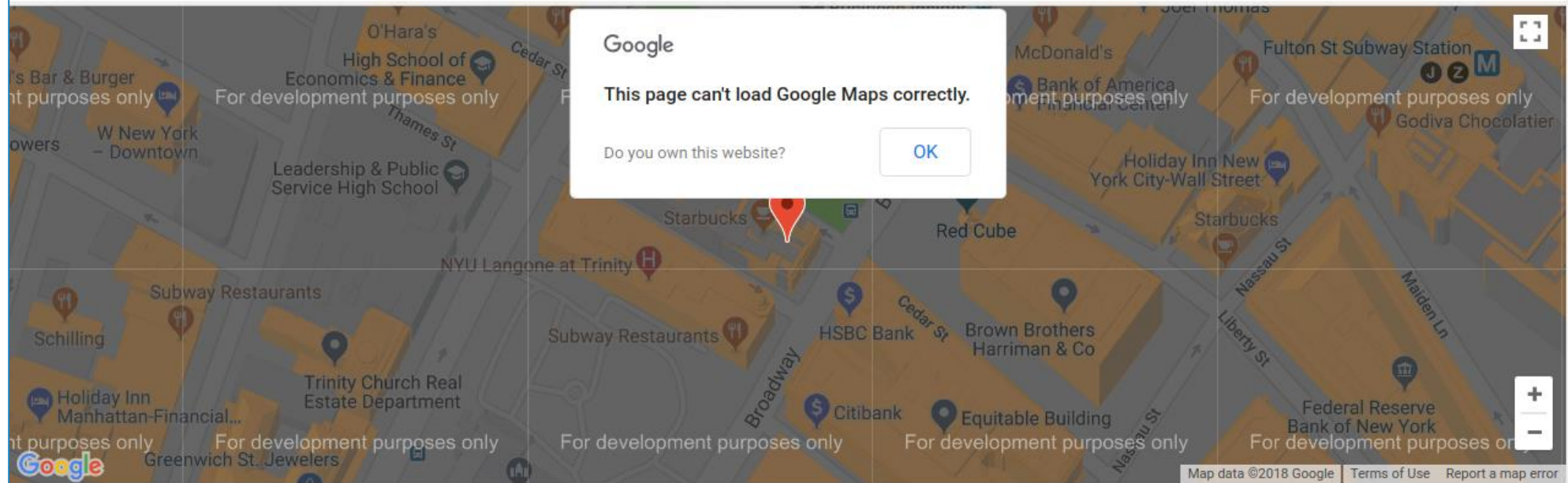
- No shrink wrapped boxes
- No 'apt install'
- No app store
- No open source

Service Providers of Financial Institution Account Connectivity

OFX Service Provider	Software Connected			Download Method		Type of Accounts that Can Download						Required Testing by Intuit		
	Quicken Windows	Quicken Mac	Quick Books	Direct Connect	Web Connect	Banking	Credit Card	Investments	401K	Pay-ments	Auto a/c setup	None*	Some Testing ¹	Full Testing ¹
Access Softek, Inc.	x	x	x	x		x					x	x		
Automated Financial Systems	x			x				x			x	x		
Automated Systems	x	x	x	x	x	x					x	x		
Cardinal Solutions	x	x	x	x	x	x	x			x				x
CheckFree	x	x	x	x		x	x			x	x			x
Corillian	x	x	x	x	x	x	x			x	x			x
Digital Insight	x	x	x	x	x	x	x			x	x	x		
DST	x	x		x	x			x			x	x		
EEI	x	x	x	x	x	x	x	x	x	x	x			x
Fidelity IFS	x	x	x		x	x							x	
Fidelity National	x			x		x				x	x			x
Financial Fusion	x	x		x		x	x			x				x
Fiserv	x	x	x	x	x	x				x	x	x		
Innovision	x	x	x	x	x	x	x	x	x		x			x
Intelidata	x	x	x	x	x	x	x			x	x			x
Jack Henry	x	x	x	x	x	x	x				x	x		
FIS/(old nameMetavante)	x	x	x	x	x	x	x	x		x	x		x	
NCR-Corillian Voyager	x	x	x	x	x	x	x			x	x	x		
Open Solutions Inc.(OSI)	x	x	x	x	x	x				x	x		x	
ORCC	x	x	x	x	x	x	x			x	x	x		
ACI Worldwide/PM Systems	x	x			x	x	x					x		
Pershing	x	x		x				x			x	x		
PSI	x	x	x	x	x	x					x			x
SciVantage	x				x			x					x	
Symitar Systems-Episis	x	x	x	x	x	x	x				x	x		

Software Vendors





Get in Touch!

API Documentation Request

Say hello... We'd love to hear from you!

* indicates a required field

Full Name *

Email *

Corporate Office

Enterprise Engineering, Inc.
115 Broadway, Suite# 1705
New York, NY 10006

Phone: 212.344.2000

Fax: 212.344.2700

Info@joineei.com

OFX Hosting



ofx.netteller.com



ofx.lanxtra.com

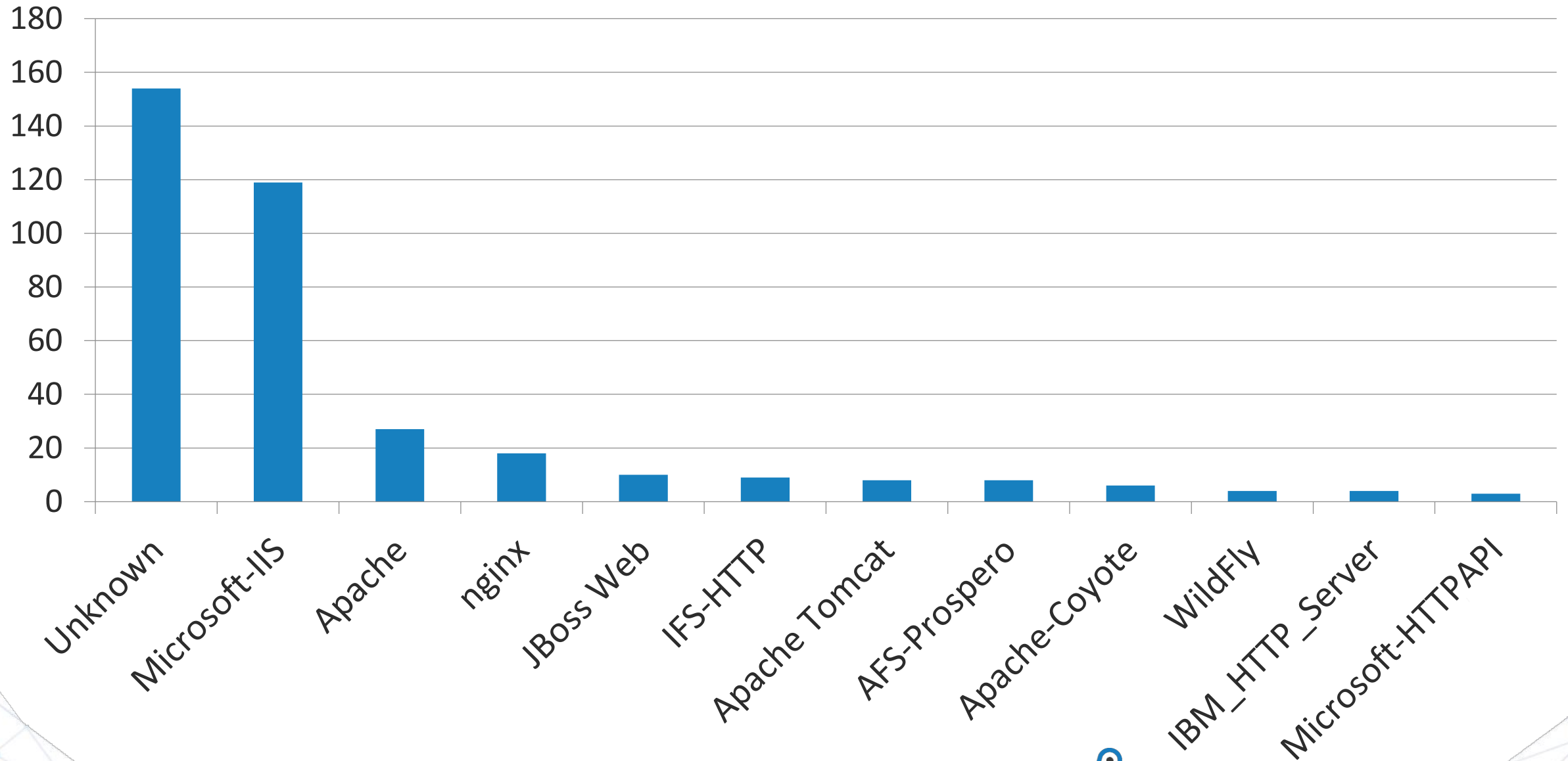


pfm.metavante.com

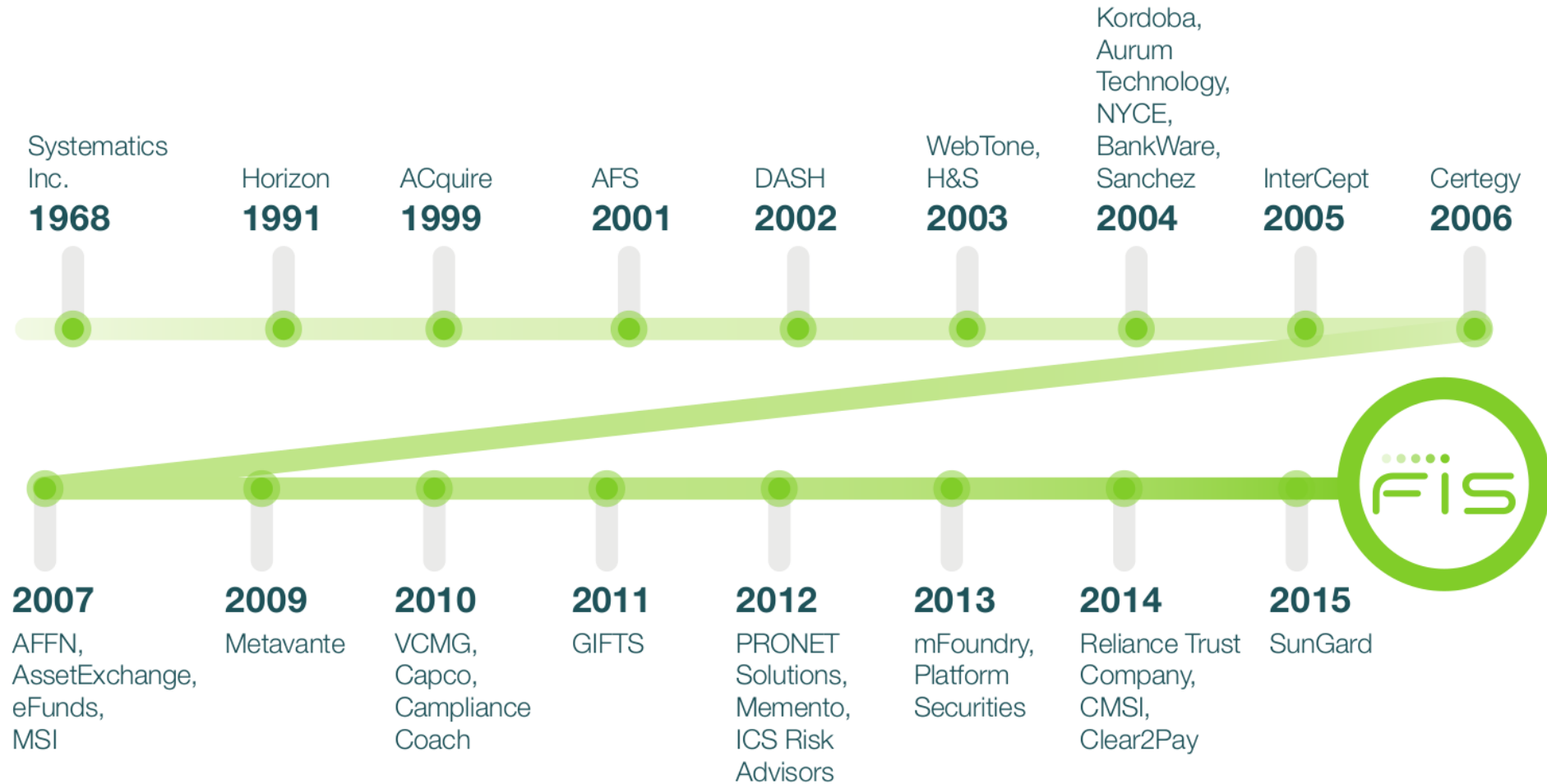


ofxdi.diginsite.com
ofxdc.prdd1.ncr.com

Frequency of HTTP Servers



Acquisition and Atrophy



Vulnerabilities

650 Page OFX specification
34 Implementations
x 10 Technology Stacks
221,000 Vulnerabilities

Found in Production

- Web server disclosure
- Web framework disclosure
- OFX server version disclosure
- Backend DB disclosure
- Full stack trace on errors
- Full server file paths in errors
- Out-of-date software
- Unhandled exceptions
- Long lived session keys
- MFA ignored
- SSN used as usernames
- Internal IP disclosure
- Valid user enumeration
- Personal email disclosure
- Unmaintained servers
- Null values returned
- Unregistered URL referenced
- Reflected XSS
 - I know it's not a web page, and yet...

Demo

ofxpostern

- Fingerprint OFX Server
- Show capabilities
- Scan for vulnerabilities

<https://github.com/sdann/ofxpostern>


```
sdanndev@ubuntu-desk:~/ofx/ofxpostern$ ./ofxpostern.py
usage: ofxpostern.py [-h] [-f FID] [-o ORG] url
ofxpostern.py: error: the following arguments are required: url
sdanndev@ubuntu-desk:~/ofx/ofxpostern$ ./ofxpostern.py -f 11135 -o Cavion https:/
/ofx.lanxtra.com/ofx/servlet/Teller
ofxpostern.py: version 0.1.0
```

```
Start: Tue Aug  7 21:43:49 2018
  Sending GET /
  Sending GET OFX Path
  Sending POST OFX Path
  Sending OFX Empty
  Sending OFX PROFILE
  Analysing Server
  Fingerprinting
  Running Tests
End:   Tue Aug  7 21:43:51 2018
```

Financial Institution

=====

```
Name:      Yolo Federal Credit Union
Address:   266 W. Main St.
           Woodland, CA 95695
           USA
```

OFX Server

OFX Server

=====

OFX Version: 1.0.2

FID: 11135

ORG: Cavion

URL: <https://ofx.lanxtra.com/ofx/servlet/Teller>

Capabilities

=====

* Banking

+ Intrabank Transfer

Fingerprint

=====

HTTP Server: Apache Tomcat/7.0.42

Web Framework:

OFX Software

Company: Finastra

Product: Cavion

Version:

```
* Banking
+ Intrabank Transfer
```

```
Fingerprint
```

```
=====
```

```
HTTP Server:  Apache Tomcat/7.0.42
```

```
Web Framework:
```

```
OFX Software
```

```
-----
```

```
Company: Finastra
```

```
Product: Cavion
```

```
Version:
```

```
Tests
```

```
=====
```

```
Multi-Factor Authentication: FAIL
```

```
* OFX protocol version (1.0.2) does not support MFA
```

```
Password Policy: FAIL
```

```
* Minimum password length (4) is less than recommended (8)
```

```
sdanndev@ubuntu-desk:~/ofx/ofxpostern$
```

Conclusions





Planning for Retirement

- **Inventory your assets**
 - How much ~~money~~ public facing services do you have?
- **Pick an age to retire**
 - How old do you want your TLS certs to be?
 - When will ~~you~~ your software stop working?
- **Do quarterly check-ins**
 - ~~Are you saving enough?~~ Is your software up to date?
- **Protect your assets**
 - With ~~insurance~~ MFA
- **Invest**
 - The earlier the better, but it is never too late to start!

Questions?

@sdanndev | www.securityinnovation.com



Glossary

- **FI** - Financial Institution
 - A bank, brokerage, or credit card provider.
- **PFM** - Personal Financial Management
 - Client software for viewing and managing their financial accounts